SECURITY

HMAC & Digital Signatures Visual Guide

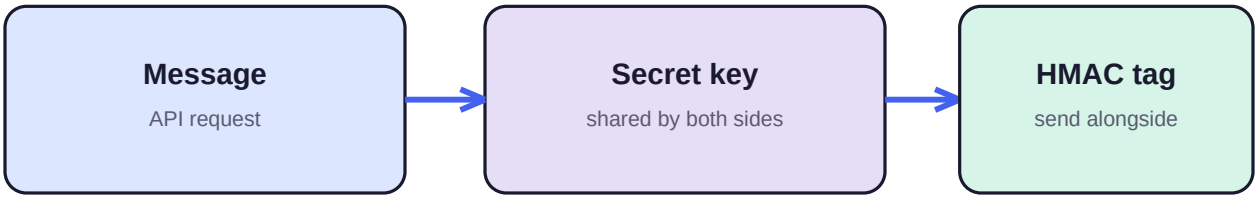
Prove a message is authentic —
and prove who sent it.

ANIMATED WALKTHROUGH
Step through pages to play the animation

STEP 1/6

HMAC: Message Authentication

Shared secret + message → tamper-evident tag.

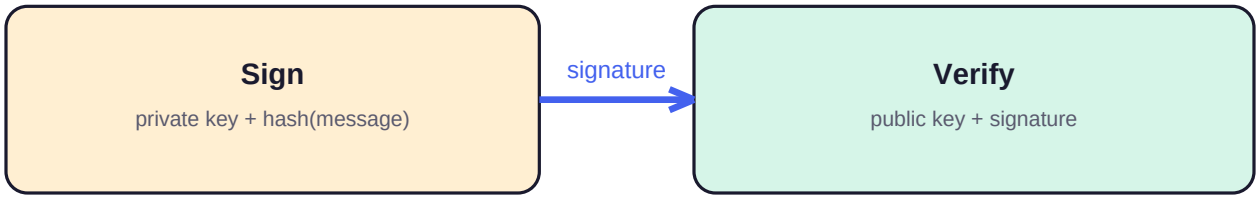


Receiver recomputes the tag with the same secret — match means authentic AND unmodified. Used in webhooks, API auth, cookie signing.

STEP 2/6

Digital Signatures: Sign & Verify

Private key signs, public key verifies — no shared secret.



Anyone can verify with the public key, but only the private-key holder could have signed. That's non-repudiation.

STEP 3/6

RSA vs ECDSA

Two workhorses, different trade-offs.

RSA

2048-bit+ keys; widely supported; bigger signatures.

ECDSA (P-256)

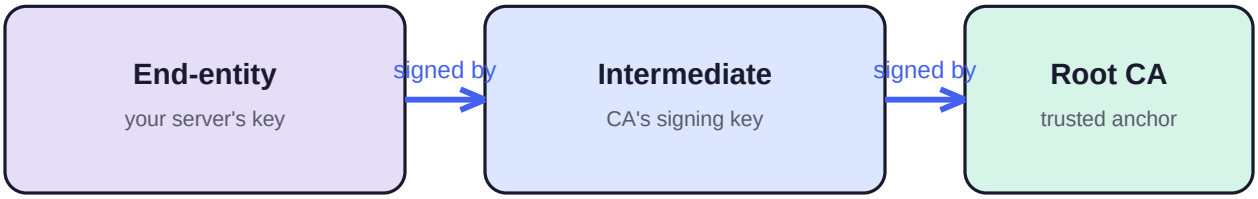
Tiny keys + fast; same security, 1/8 the size.

Always sign the HASH of the message, never the raw message. And use a modern padding/scheme — textbook RSA is broken.

STEP 4/6

Certificates Bind Keys to Identity

A public key is useless if you don't know whose it is.



The chain lets a stranger's signature become trustworthy: each link vouches for the one below, anchored at a root you already trust.

STEP 5/6

HMAC vs Signatures — When

Symmetric speed vs asymmetric trust.

HMAC

Both sides share a secret. Fast. Use: webhooks, API keys, sessions.

Signatures

Public verification. Use: JWTs, code signing, certificates.

STEP 6/6

Key Handling Pitfalls

The math is solid; the handling is where it breaks.

- HMAC keys must be random 256-bit — 'secret' as a string is crackable.
- Compare tags in constant time — naive == leaks the tag byte-by-byte.
- Protect private keys in a KMS/HSM; never commit them to repos.
- Timestamp + nonce on signed messages to block replay attacks.

STEP ✓I✓

Key Takeaways

HMAC & Signatures — Remember

- HMAC proves authenticity with a shared secret; signatures prove it with key pairs.
- Sign the hash, not the message; use modern schemes and padding.
- Certificates bind public keys to identities via a chain to a trusted root.
- HMAC for webhooks/API auth; signatures for JWTs, code, and certificates.
- Compare tags in constant time; keep private keys in KMS/HSM.

Keep exploring

Pair this guide with the matching video walkthroughs
and hands-on labs at interstitiumlabs.dev